VinSOC

Trợ lý điều tra SOC dựa trên bằng chứng

Công việc đã thực hiện và kết quả thực nghiệm

Cập nhật ngày 15 tháng 10 năm 2026

Mục tiêu và kết quả chính

VinSOC hỗ trợ người phân tích SOC điều tra cảnh báo, IOC và câu hỏi về dữ liệu mạng. Hệ thống lựa chọn nguồn cần tra cứu, bổ sung ngữ cảnh, phân tích dữ liệu, lưu dẫn chứng và tạo nhận định để người phân tích xem xét. Hai trọng tâm thực nghiệm là độ chính xác gọi công cụ R1 và độ chính xác Text-to-SQL R2.

Các thành phần đã có gồm bộ điều phối dùng mô hình ngôn ngữ, công cụ CTI, network và endpoint, dịch vụ Text-to-SQL, kho dẫn chứng, kiểm chứng kết quả và giao diện theo dõi điều tra. Đã có các lượt gọi mô hình và thực thi truy vấn thật; một số tình huống thành công, một số bị dừng hoặc trả lời sai và được giữ lại để phân tích.

Hạng mục	Công việc đã thực hiện
R1 gọi công cụ	Xây schema ba công cụ; chấm chọn tool, tham số, gọi thừa và không gọi tool. Chuẩn bị thêm bộ 120 ca đã duyệt.
R2 Text-to-SQL	Tích hợp sinh SQL với DuckDB; có cấu hình trực tiếp và cấu hình dùng linker; thiết kế 96 câu evaluation đa lĩnh vực.
Điều tra có dẫn chứng	Thu kết quả công cụ, gắn nguồn, kiểm nhận định và đưa hồ sơ đến bước review.
Giao diện và vận hành	Theo dõi từng bước chạy; xem kết quả, lỗi, thời gian và chi phí; mở lại hồ sơ đã lưu.

Vấn đề cần hoàn thiện

Triage ban đầu hiện dựa trên quy tắc phân loại văn bản, chưa bảo đảm mọi kết luận đều đi sau enrichment và kiểm tra hành vi. Điểm phát triển R1 đạt 91,67% trên 24 ca; R2 từng đạt 87,5% trên 8 câu CTU. Hai kết quả này chưa phải điểm của các bộ mở rộng 120 và 96 ca.

1 Triage và phạm vi điều tra

Cơ chế triage hiện tại

Luồng IOC cũ ghép chỉ báo và ngữ cảnh cảnh báo, nhận diện cụm từ bằng quy tắc, xử lý phủ định rồi gán nhãn benign, suspicious hoặc needs investigation. Đây là bước sàng lọc theo nội dung được cung cấp, chưa phải kết luận hình thành từ bằng chứng CTI, lưu lượng hay hoạt động máy trạm.

Nếu nhãn ban đầu là benign và có human review, hệ thống hỏi người phân tích có đóng cảnh báo hay tiếp tục điều tra. Khi không cấu hình human review, nhánh cũ vẫn có thể tự đóng trước enrichment. Việc kết luận từ nội dung cảnh báo trước khi thu thập bằng chứng làm hạn chế chất lượng điều tra. Các công cụ phân tích ở bước sau chưa khắc phục nhánh đóng sớm này.

Các bước điều tra đã được triển khai

Khi tiếp tục điều tra, bộ điều phối lựa chọn công cụ theo yêu cầu. CTI bổ sung thông tin về IOC; network tìm kết nối và đặc trưng hành vi; endpoint truy lại máy trạm và quan hệ tiến trình. Kết quả được lưu thành dẫn chứng trước khi tạo nhận định, kiểm tính truy nguồn và chuyển cho người duyệt.

Loại thông tin	Vai trò trong quyết định
Cảnh báo đầu vào	Nêu lý do bắt đầu và các đối tượng cần điều tra; chưa đủ để kết luận độc hại hay an toàn.
Bằng chứng thu thập	Cho biết IOC có trong nguồn CTI không, máy nào đã kết nối, hành vi nào xuất hiện và thời điểm liên quan.
Nhận định sau điều tra	Tổng hợp bằng chứng ủng hộ, mâu thuẫn và phần còn thiếu; người phân tích xem xét quyết định cuối.

Hạn chế và hướng hoàn thiện triage

Hướng hoàn thiện là tách bước tiếp nhận và ưu tiên xử lý khỏi kết luận cuối. Kết luận benign cần có bằng chứng phù hợp từ các nguồn đã tra và dữ liệu hành vi, thay vì chỉ dựa vào từ khóa. Khi thiếu dữ liệu, hồ sơ cần giữ trạng thái chưa đủ bằng chứng. Việc chuyển triage sang quyết định sau enrichment chưa được hoàn tất trong luồng IOC hiện tại.

Luồng câu hỏi Text-to-SQL chỉ xác thực câu hỏi và phạm vi dữ liệu trước truy vấn. Bước đó không thực hiện phân loại đe dọa và không thay thế triage cảnh báo.

2 Enrichment và kiểm tra hành vi

CTI và kiểm tra liên quan đến C2

CTI tra IOC trong nguồn được cấu hình để lấy bản ghi khớp, họ malware, loại mối đe dọa và thông tin kỹ thuật liên quan. ATT&CK bổ sung ngữ cảnh kỹ thuật khi có tên phần mềm hoặc kỹ thuật phù hợp. Không có bản ghi CTI không đồng nghĩa IOC an toàn.

Với nghi vấn C2, phần network nhóm các flow theo IP nguồn, IP đích, cổng đích và giao thức, rồi đo khoảng cách thời gian giữa các kết nối. Mặc định cần ít nhất bốn flow; hệ số biến thiên khoảng thời gian không quá 0,30 được đánh dấu là ứng viên kết nối định kỳ. Đây là dấu hiệu phục vụ điều tra, chưa phải xác nhận C2.

Kiểm tra network	Thông tin trả về
Kết nối định kỳ	Số flow, trung bình và trung vị khoảng cách thời gian, độ lệch và danh sách sự kiện liên quan.
Ứng viên quét ngang hoặc dọc	Trong cửa sổ 60 giây, mặc định từ tám đích khác nhau trên một cổng hoặc tám cổng trên một đích.
Lưu lượng truyền	Tổng byte ra và vào, tỷ lệ hai chiều, số kết nối và phạm vi nội bộ hoặc bên ngoài nếu đã cấu hình.
Truy cập dịch vụ quản trị	Ứng viên một nguồn liên hệ từ bốn đích nội bộ trên các cổng quản trị; cần ngữ cảnh tài sản để giải thích.

Đối chiếu trên máy trạm

Endpoint lấy cây tiến trình theo host và khoảng thời gian, kiểm các quan hệ như Office khởi chạy PowerShell, ứng dụng thông thường sinh công cụ hệ thống, hoặc PowerShell sinh rundll32 và mshta. Kết quả gồm quan hệ cha con, lý do nghi vấn và kỹ thuật ATT&CK tương ứng nếu có.

Để củng cố một giả thuyết C2, người phân tích cần đối chiếu đích trong CTI, kết nối thực tế và tiến trình liên quan trong cùng ngữ cảnh thời gian. Hệ thống đã có các nguồn và phép phân tích nêu trên, nhưng chưa có bộ đo xác nhận C2 đầu cuối. Flow định kỳ, tỷ lệ byte lớn hay tên tiến trình riêng lẻ chưa đủ kết luận xâm nhập.

Network hiện tra theo IPv4. Tra cứu chỉ bằng tên miền và tương quan DNS hoặc TLS chưa được hỗ trợ trong nguồn flow hiện tại. Công cụ cũng cần dữ liệu đã cấu hình; không có dữ liệu phù hợp phải được báo thiếu.

3 Các công cụ điều tra của hệ thống

VinSOC có chín tên công cụ được cung cấp cho mô hình trong các profile khác nhau. Không có một lượt điều tra nào mặc định được quyền dùng toàn bộ công cụ. R1 hiện chỉ chấm ba công cụ điều tra ở nhóm đầu.

Công cụ	Chức năng và đầu vào
cti_enrichment	Tra thông tin CTI cho IP, tên miền, URL hoặc hash theo khả năng nguồn. Trả bản ghi khớp, ngữ cảnh đe dọa và nguồn; không dùng để tra hostname máy trạm.
network_investigation	Nhận IPv4 và khoảng thời gian để tìm flow, thống kê kết nối, cổng và đích, kiểm định kỳ, quét và lưu lượng. Không nhận SQL từ mô hình ở lớp điều phối.
endpoint_investigation	Nhận host và khoảng thời gian, tìm sự kiện máy trạm, cây tiến trình và quan hệ cha con nghi vấn.
network_query	Nhận nguyên văn câu hỏi mạng. Gọi dịch vụ Text-to-SQL trên snapshot được cấp và trả kết quả truy vấn kèm dẫn chứng.
soc_search_events	Tìm sự kiện theo host, user, nguồn, nội dung và thời gian trong hồ sơ SOC traces đang được cấp. Dữ liệu ở profile này là dữ liệu tổng hợp.
soc_get_context	Lấy cây tiến trình, thông tin tài sản hoặc cảnh báo liên quan của cùng hồ sơ SOC traces. Dữ liệu không có được trả là unavailable hoặc no match.

Quy tắc sử dụng

Công cụ chỉ đọc dữ liệu trong phạm vi được cấp. Một yêu cầu có thể cần một, nhiều hoặc không cần công cụ. Thiếu IP, host hoặc phạm vi thời gian cần thiết phải dẫn đến hỏi thêm hoặc nêu giới hạn, thay vì tự tạo thông tin.

Các công cụ SOC traces phục vụ luồng thí nghiệm trên dữ liệu tổng hợp, chưa kết nối trực tiếp đến SIEM sản xuất. Adapter cho Google SecOps, GTI và SCC mới ở dạng khung tích hợp, chưa có kết nối vận hành được xác minh.

4 Công cụ dữ liệu và hạ tầng hỗ trợ

Ba công cụ bên trong cấu hình R2 có linker

Công cụ	Vai trò
database_profiler	Khảo sát bảng và các cột được phép để hỗ trợ hiểu cấu trúc và dữ liệu trước khi sinh SQL.
value_search	Tìm giá trị thực trong cột bằng đối sánh chính xác, tiền tố hoặc chuỗi con. Trả dẫn chứng giá trị để tránh tự suy diễn điều kiện lọc.
sql_probe	Thử truy vấn chỉ đọc trong môi trường cách ly để kiểm ý tưởng hoặc dữ liệu. Kết quả thử không thay bằng chứng giá trị theo hợp đồng của value_search.

Nguồn enrichment được hỗ trợ

Nguồn	Chức năng và điều kiện sử dụng
ThreatFox	Tra IOC và ngữ cảnh đe dọa từ abuse.ch; có adapter API và khả năng dùng dữ liệu cục bộ được cấu hình.
MalwareBazaar	Tra hash tệp; không áp dụng cho mọi loại IOC.
URLhaus	Tra IOC trong dữ liệu URLhaus cục bộ khi đã cung cấp tệp nguồn.
MITRE ATT&CK	Ánh xạ phần mềm và malware sang kỹ thuật từ dữ liệu STIX cục bộ. Đây là cơ sở tri thức, không phải dịch vụ chấm uy tín IP.

Các nguồn CTI chỉ hoạt động khi đã được cấu hình dữ liệu và quyền truy cập phù hợp. Khi nguồn chưa khả dụng, công cụ trả trạng thái lỗi hoặc thiếu dữ liệu. Các demo hiện có chưa xác minh đồng thời toàn bộ nguồn CTI.

Thành phần thực thi

DuckDB lưu và truy vấn snapshot; SQLGlot kiểm cấu trúc và chính sách SQL. Worker Linux dùng bubblewrap và giới hạn tài nguyên để chạy truy vấn chỉ đọc, tách mạng và bí mật khỏi môi trường thực thi. OpenAI cung cấp các mô hình đã chọn; Streamlit cung cấp giao diện thao tác và xem hồ sơ. Kho dẫn chứng giữ dữ liệu, nguồn và quan hệ giữa kết quả với nhận định.

Cấu hình R2 trực tiếp sử dụng generator. Cấu hình R2 có linker sử dụng thêm ba công cụ DB nói trên. Routing và assessment thuộc lớp điều phối điều tra, được đo riêng với độ chính xác sinh SQL.

5 Dữ liệu và thiết kế đánh giá

R1 mở rộng gồm 120 ca mới

Quyết định cần thực hiện	Số ca
Không gọi công cụ	24
Một công cụ	54
Hai công cụ	30
Ba công cụ	12
Tổng bộ mới	120

Mỗi tool có 18 ca đơn; mỗi cặp tool có 10 ca; 12 ca cần cả ba. Bộ mới bao phủ mức cơ bản, trung bình và nâng cao, có ít nhất 30 ca robustness. Hai gói review đã hoàn tất và bộ ca đã khóa. Chưa có kết quả model đủ 120 ca để công bố điểm mới.

R2 gồm calibration và evaluation riêng

Tập	Ngoài SOC	CTU	Tổng câu
Calibration	16	8	24
Evaluation	64	32	96
Tổng câu mới	80	40	120

Mỗi câu chạy hai cấu hình E0 và E3, tạo 48 record calibration và 192 record evaluation theo thiết kế. Số record không phải số câu độc lập. Calibration dùng chọn cấu hình; evaluation dùng đánh giá sau lựa chọn, giữ nguyên mẫu số và các ca lỗi.

Evaluation ngoài SOC lấy từ Spider, gồm tám database thuộc bảy lĩnh vực. Toàn bộ 96 câu có 24 cơ bản, 48 trung bình và 24 nâng cao, bao phủ JOIN, truy vấn lồng, nhóm, thứ tự, NULL và thời gian. Bộ này là subset thích nghi cho DuckDB, không phải điểm Spider chính thức.

Nguồn CTU dùng snapshot S5 và S7 có 243.906 flow. Đã kiểm dữ liệu và thực thi 120 truy vấn gold để kiểm tính hợp lệ của bộ mới; đây là kiểm bộ đo, không phải 120 câu mô hình trả lời đúng. Pipeline tích hợp 32 câu CTU là phép đo riêng.

6 Kết quả đánh giá R1

Kết quả đã đo dưới đây thuộc bộ phát triển 24 ca, dùng GPT-4.1 mini trong một lượt quyết định native tool call. Phép đo kiểm tool và tham số được chọn, không thực thi các công cụ để chấm thành công điều tra.

Metric	Kết quả	Cách đọc
Single Turn Case Success	22/24 = 91,67%	Tỷ lệ ca hoàn tất đúng yêu cầu chọn tool và tham số.
Exact Call F1	95,08%	Cân bằng precision và recall của lời gọi tool đúng.
No Tool Accuracy	5/5 = 100%	Đúng trên năm ca không cần gọi tool.
Tool Set Exact Match	22/24 = 91,67%	Tập tên tool dự đoán khớp tập cần dùng.
Forbidden Tool Rate	0/24 = 0%	Không có ca gọi tool bị cấm trong lượt này.

Kết quả triển khai

Bộ chấm phân biệt chọn sai nguồn, thiếu tool, gọi thừa, lặp lời gọi và sai tham số. Các ca nhiều tool kiểm khả năng phối hợp CTI, network và endpoint; các ca không tool kiểm khả năng dừng khi yêu cầu chỉ mang tính khái niệm hoặc thiếu căn cứ.

Giới hạn của kết quả

Đây là dữ liệu phát triển đã dùng để điều chỉnh hệ thống. Một phần gold đã được rà soát sau khi xem đầu ra ban đầu, nên điểm 91,67% không là bằng chứng holdout độc lập. Nó cũng không đo chất lượng thực thi công cụ, nhận định cuối hoặc điều tra nhiều lượt.

Bộ 120 ca mở rộng được giữ riêng để tạo bằng chứng tốt hơn về khả năng khái quát. Trạng thái hiện tại là đã chuẩn bị và khóa bộ ca; chưa có điểm đầy đủ trên 120 ca. Khi có lượt chạy hợp lệ sẽ báo số đúng trên 120, khoảng tin cậy và các nhóm hành vi, không ghép với 22/24.

7 Kết quả đánh giá R2

Kết quả phát triển CTU trước khi mở rộng

Metric trên 8 câu CTU	Kết quả
Execution Accuracy	7/8 = 87,5%
Execution Success	7/8 = 87,5%
Syntax Validity	7/8 = 87,5%
Safety Rejection Rate	0/8 = 0%

Một ca không hoàn tất trong giới hạn gọi công cụ và vẫn nằm trong mẫu số. Kết quả 87,5% thuộc tám câu phát triển CTU, không phải kết quả trên 96 câu evaluation. Không bị safety rejection chỉ nói rằng không quan sát từ chối trong lượt này; chưa chứng minh an toàn trên đầu vào độc hại.

Calibration mở rộng trên cùng 24 câu mỗi cấu hình

Cả hai cấu hình calibration dùng GPT-5 mini, reasoning mức low, tối đa 1.000 output token mỗi request và không retry. E0 sinh SQL trực tiếp; E3 dùng linker, công cụ DB và generator trong ngân sách lượt gọi đã giới hạn.

Lượt calibration	EX E0	EX E3	Phản hồi
Lượt chọn cấu hình	15/24 = 62,5%	5/24 = 20,83%	139
Lượt tiếp theo	15/24 = 62,5%	4/24 = 16,67%	144

Lượt chọn cấu hình có E0 chạy SQL thành công 23/24 và E3 5/24; chi phí lần lượt khoảng 0,01805 và 0,14953 USD. Quy tắc lựa chọn đã chọn E0. Lượt tiếp theo có E0 thực thi thành công 22/24, E3 5/24; tổng chi phí khoảng 0,17346 USD. Hai lượt được báo riêng, không lấy kết quả tốt nhất ghép thành một lượt.

Execution Success cho biết truy vấn chạy được; Execution Accuracy còn yêu cầu kết quả đúng gold. Ở lượt chọn cấu hình, E0 có tám truy vấn chạy được nhưng trả kết quả khác đáp án. E3 thường dừng trước SQL cuối vì lỗi liên kết schema, đầu ra không hợp lệ hoặc truy vấn thử thất bại.

Evaluation 96 câu chưa có đủ 192 record kết quả để tổng hợp Execution Accuracy. Các lượt calibration trên cũng chưa có phép đo ngữ nghĩa bằng dữ liệu phản ví dụ; chỉ số này hiện chưa được xác lập.

8 Luồng đầu cuối và kết quả demo

Luồng xử lý câu hỏi mạng

Người dùng hỏi số IP đích nhận TCP flow trong cả hai scenario CTU sau hai mốc thời gian riêng. Bộ điều phối giữ nguyên câu hỏi khi gọi network_query. Dịch vụ R2 tạo truy vấn, worker chạy trên snapshot được cấp và trả bảng kết quả. Kho dẫn chứng lưu kết quả cùng nguồn; assessment diễn giải con số và nêu giới hạn trước khi đưa cho người phân tích review.

Ở demo COUNT, kết quả là 459 IP. Kiểm thực thi, so sánh đáp án và dẫn chứng đạt; hồ sơ còn chờ người duyệt. Con số 459 mô tả dữ liệu thỏa điều kiện truy vấn, không có nghĩa 459 IP độc hại hoặc có liên quan C2.

Tình huống	Kết quả quan sát	Trạng thái
COUNT IP chung	459 IP, kết quả khớp đáp án và có dẫn chứng.	Chờ duyệt
AVG theo giao thức	TCP, một lượt đã đạt kiểm kỹ thuật.	Chờ duyệt
Đếm khi byte là NULL	Mô hình làm mất các nhóm có số đếm bằng 0.	Sai kết quả
UDP chỉ có ở S5	Giữ được 9.780 hàng; dữ liệu vượt giới hạn đưa vào assessment.	Chưa hoàn tất

Bốn demo cho thấy hai ca đạt kiểm kỹ thuật, một ca sai và một ca dừng trước assessment. Một lượt AVG khác cũng gặp lỗi truy vấn thử, cho thấy thành công ở một lần chưa chứng minh ổn định. Các demo không thay kết quả benchmark 96 câu hoặc phép đo pipeline 32 câu.

Luồng cảnh báo ngoài Text-to-SQL

Hệ thống cũng đã chạy một ca SOC traces bằng API thật. Mô hình tìm sự kiện và lấy ngữ cảnh; các công cụ trả không khớp hoặc không có dữ liệu. Kết luận cuối là chưa đủ bằng chứng. Ca này sử dụng dữ liệu tổng hợp, không phản ánh một sự cố sản xuất thực tế. Khả năng xác nhận C2 đầu cuối chưa được đánh giá trên một bộ sự cố riêng.

9 Đánh giá và công việc tiếp theo

Kết quả triển khai và đánh giá

VinSOC đã kết nối quyết định gọi công cụ với thu thập dữ liệu, Text-to-SQL, kết quả truy vấn, dẫn chứng, nhận định và review. Các lỗi được giữ lại theo đúng bước phát sinh, giúp phân biệt lỗi lựa chọn nguồn, lỗi sinh SQL, lỗi giới hạn dữ liệu và thiếu thông tin điều tra.

Ưu tiên	Công việc cần hoàn thiện	Điều kiện đánh giá
Triage sau enrichment	Tách sàng lọc ban đầu khỏi kết luận; không đóng benign khi chưa có bằng chứng phù hợp.	Theo dõi CTI, flow, endpoint và lý do quyết định cuối.
R1 mở rộng	Hoàn thiện gate chạy, thống kê và workflow; chạy đúng một suite được cấp quyền.	Đủ 120 ca, báo điểm và khoảng tin cậy theo nhóm.
R2 đa lĩnh vực	Chạy đủ 96 câu với E0/E3, kiểm hồ sơ và giữ đúng phạm vi lựa chọn cấu hình.	Đủ 192 record, tách ngoài SOC 64 và CTU 32.
R2 linker và assessment	Cải thiện đầu ra có cấu trúc, dẫn chứng giá trị và xử lý kết quả dài.	Đo lại theo phiên bản mới; không thay kết quả đã lưu.
Review đầu cuối	Bổ sung quyết định, lý do và người chịu trách nhiệm cho hồ sơ hợp lệ.	Phân biệt đạt kỹ thuật với được người phân tích duyệt.

Kết luận

Kết quả hiện tại chứng minh khả năng tích hợp và tạo hồ sơ có thể kiểm tra lại. Những điểm mạnh đã đo là R1 đạt 22/24 trên bộ phát triển và R2 từng đạt 7/8 trên CTU. Calibration đa lĩnh vực cho thấy cấu hình nhiều bước chưa ổn định và cần cải thiện trước khi kết luận về khả năng khái quát.

Trọng tâm tiếp theo là triage dựa trên bằng chứng sau enrichment, hoàn tất đánh giá R1 trên 120 ca và R2 trên 96 câu, đồng thời đo riêng thành công đầu cuối. Quy mô bộ đo, số ca thực sự đã chạy và điểm đạt phải tiếp tục được trình bày tách biệt.

Tài liệu và dữ liệu đối chiếu

Tài liệu chức năng và kết quả thực nghiệm VinSOC; CTU-13 của Stratosphere IPS; Spider của Yale LILY; ThreatFox, MalwareBazaar và URLhaus của abuse.ch; MITRE ATT&CK. Phần benchmark ngoài SOC sử dụng subset được thích nghi, không là kết quả chính thức trên toàn bộ Spider.